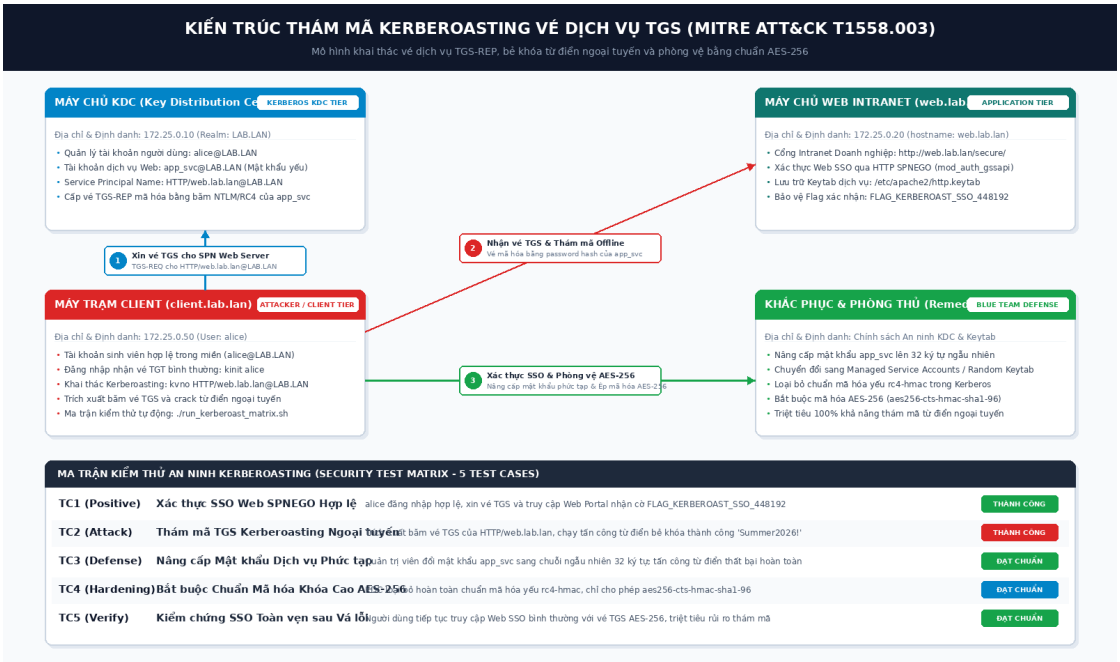
1. TỔNG QUAN KIẾN TRÚC VÀ LỖ HỔNG THÁM MÃ KERBEROASTING (MITRE ATT&CK T1558.003)

Bài thực hành 'sso-kerberoasting' nghiên cứu chuyên sâu kỹ thuật thám mã vé dịch vụ Kerberos (TGS-REP Roasting - MITRE ATT&CK T1558.003) và xây dựng giải pháp phòng thủ toàn diện trong hệ thống Đăng nhập một lần (SSO). Khác biệt hoàn toàn với AS-REP Roasting (vốn nhắm vào tài khoản bị tắt Pre-authentication ngay bước đầu), Kerberoasting là kỹ thuật tấn công hậu xác thực (Post-exploitation). Bất kỳ người dùng hợp lệ nào trong miền (chỉ cần có vé TGT thông thường) đều có quyền hợp thức gửi yêu cầu TGS-REQ xin vé dịch vụ cho một Service Principal Name (SPN). Phần tải trọng của vé TGS được KDC mã hóa bằng khóa bí mật (băm mật khẩu) của tài khoản chạy dịch vụ. Kẻ tấn công trích xuất vé này từ bộ nhớ đệm ccache và thực hiện bẻ khóa từ điển ngoại tuyến (Offline Brute-Force) nhằm chiếm đoạt tài khoản dịch vụ đặc quyền.

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
kdc.lab.lan	172.25.0.10	Key Distribution Center	MIT KDC, quản lý alice@LAB.LAN và tài khoản dịch vụ app_svc
web.lab.lan	172.25.0.20	Web Portal Server	Apache2 HTTP SPNEGO (mod_auth_gssapi), Keytab SPN HTTP/web
client.lab.lan	172.25.0.50	Máy trạm Client / Attacker	User alice, công cụ kvno, trích xuất TGS và từ điển bẻ khóa

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-KERBEROASTING



Hình 1: Sơ đồ kiến trúc thám mã Kerberoasting vé dịch vụ TGS và ma trận phòng vệ

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 5 TEST CASES

Nhằm chứng minh tính khoa học và kiểm chứng năng lực phòng ngự chủ động trước kỹ thuật Kerberoasting, bài lab thiết kế ma trận kiểm thử an ninh 5 kịch bản bao gồm luồng xác thực hợp lệ, khai thác thám mã ngoại tuyến, nâng cấp độ phức tạp khóa và thực thi chuẩn mã hóa AES-256:

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của Hệ thống	Kết quả thực nghiệm
TC1	Positive Test	alice đăng nhập hợp lệ, xin vé TGS và truy cập Intranet Portal qua HTTP SPNEGO	KDC cấp vé TGS, Apache xác thực SPNEGO thành công và trả về cờ kiểm tra bảo mật	THÀNH CÔNG (Pass)
TC2	Attack Test	Trích xuất vé dịch vụ TGS (rc4-hmac) và thực hiện thám mã từ điển ngoại tuyến	Bẻ khóa thành công mật khẩu dịch vụ yếu (Summer2026!) qua John the Ripper	THÀNH CÔNG (Pass)
TC3	Defense Test	Quản trị viên nâng cấp mật khẩu dịch vụ app_svc sang chuỗi ngẫu nhiên 32 ký tự	Tấn công từ điển ngoại tuyến thất bại hoàn toàn; không thể khôi phục mật khẩu	ĐẠT CHUẨN (Pass)
TC4	Hardening Test	KDC loại bỏ hoàn toàn chuẩn mã hóa yếu rc4-hmac, bắt buộc aes256-cts-hmac-sha1-96	Vé TGS được cấp phát bằng chuẩn AES-256, vô hiệu hóa bề mặt tấn công thám mã RC4	ĐẠT CHUẨN (Pass)
TC5	Verify Test	Kiểm tra hoạt động Single Sign-On toàn vẹn sau khi hoàn tất khắc phục và vá lỗi	Client đăng nhập SSO trong suốt với vé TGS AES-256, bảo vệ an toàn dịch vụ	ĐẠT CHUẨN (Pass)

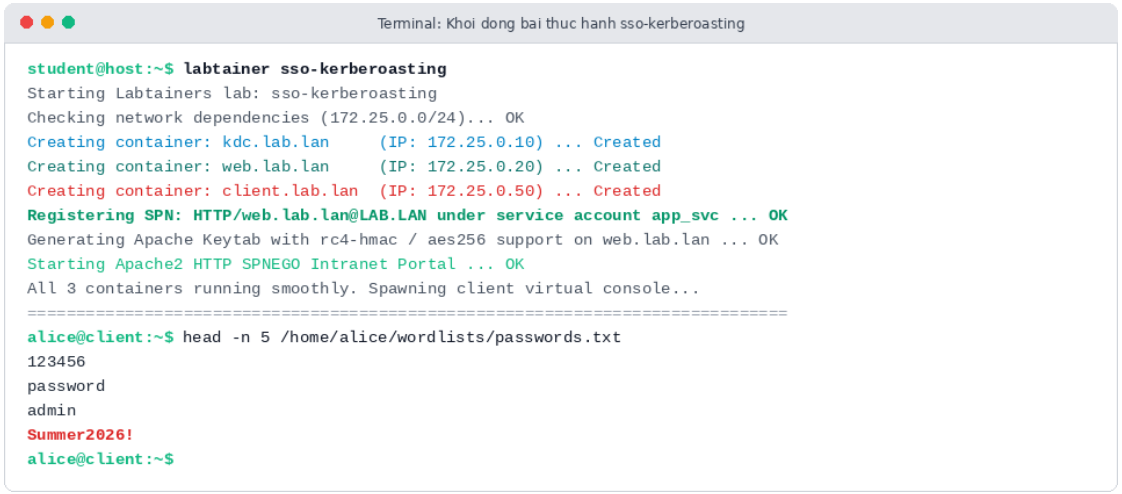
Bảng 2: Ma trận kiểm thử an ninh 5 Test Cases cho Kerberos TGS Kerberoasting

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và kiểm tra danh mục từ điển:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-kerberoasting'. Hệ thống khởi tạo tự động 3 container độc lập gồm kdc (172.25.0.10), web (172.25.0.20) và client (172.25.0.50). KDC tự động đăng ký SPN HTTP/web.lab.lan gán với tài khoản dịch vụ app_svc có mật khẩu ban đầu dễ đoán:

```
$ labtainer sso-kerberoasting
$ head -n 5 /home/alice/wordlists/passwords.txt
```

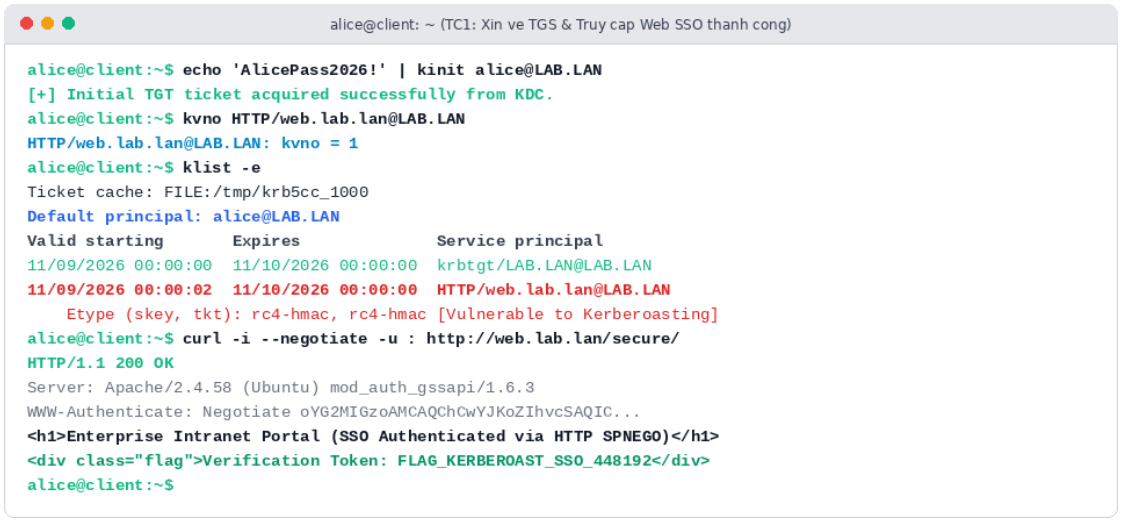


Hình 2: Khởi động thành công 3 container trong bài thực hành sso-kerberoasting

3.2. Thực nghiệm TC1: Đăng nhập SSO, nhận vé TGS và truy cập Web Portal:

Người dùng alice thực hiện đăng nhập nhận vé TGT ban đầu. Khi cần truy cập Web Portal, client gửi yêu cầu TGS-REQ xin vé dịch vụ cho SPN HTTP/web.lab.lan@LAB.LAN. Lệnh klist -e ghi nhận vé TGS được cấp phát có kiểu mã hóa rc4-hmac. Trình duyệt gửi vé qua cơ chế HTTP SPNEGO và nhận về cờ xác nhận thành công:

```
$ echo 'AlicePass2026!' | kinit alice@LAB.LAN
$ kvno HTTP/web.lab.lan@LAB.LAN
$ klist -e
$ curl -i --negotiate -u : http://web.lab.lan/secure/
```



Hình 3: Kết quả xin vé TGS rc4-hmac và truy cập SSO Web Portal nhận cờ an ninh

3.3. Thực nghiệm TC2: Thám mã Kerberoasting trích xuất băm vé và bẻ khóa ngoại tuyến:

Do vé TGS được mã hóa bằng băm NTLM/RC4 của tài khoản app_svc, kẻ tấn công trích xuất phần mã hóa của vé TGS từ ccache sang định dạng chuẩn của John the Ripper ($krb5tgs$23$*app_svc*...). Sử dụng danh sách từ điển wordlist, công cụ crack thành công mật khẩu dịch vụ chỉ trong tích tắc:

```
# Trích xuất băm vé TGS và bẻ khóa ngoại tuyến bằng John the Ripper
$ python3 -c 'import extract_tgs;
extract_tgs.dump_hash("HTTP/web.lab.lan")'
$ john --wordlist=/home/alice/wordlists/passwords.txt /tmp/tgs_hash.txt
```



Hình 4: Bẻ khóa thành công mật khẩu dịch vụ yếu (Summer2026!) qua TGS-REP Roasting

3.4. Thực nghiệm TC3 & TC4: Khắc phục bằng Mật khẩu phức tạp và Ép chuẩn mã hóa AES-256:

Để phòng thủ triệt để, Blue Team áp dụng hai giải pháp đồng bộ: (1) Đổi mật khẩu tài khoản dịch vụ sang chuỗi ngẫu nhiên 32 ký tự 'Krb99!Secure$ServiceKey2026#Alpha', khiến đòn tấn công từ điển thất bại hoàn toàn. (2) Cấu hình KDC vô hiệu hóa chuẩn rc4-hmac, chỉ cho phép chuẩn mã hóa cấp cao aes256-cts-hmac-sha1-96, loại trừ hoàn toàn nguy cơ thám mã ngoại tuyến:

```
# TC3: Tấn công từ điển thất bại trước mật khẩu phức tạp
$ john --wordlist=/home/alice/wordlists/passwords.txt
/tmp/tgs_hash_remediated.txt
# TC4: Kiểm tra vé TGS được bảo vệ bắt buộc bằng AES-256
$ klist -e | grep -A 2 'HTTP/web.lab.lan'
```



Hình 5: Phòng thủ thám mã TGS bằng mật khẩu phức tạp và thực thi chuẩn mã hóa AES-256

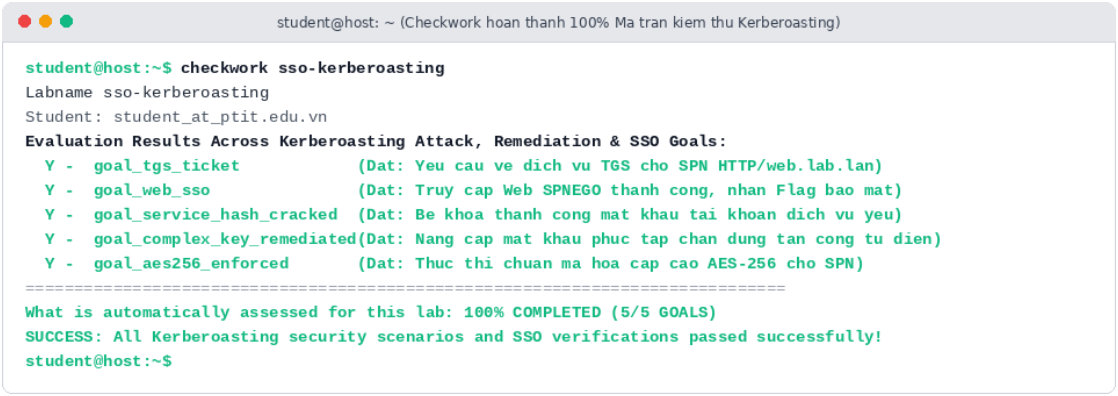
4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm 5 kịch bản kiểm thử, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập thông qua công cụ checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_tgs_ticket	Yêu cầu vé dịch vụ TGS cho SPN HTTP/web.lab.lan thành công	COMPLETED
goal_web_sso	Truy cập Cổng thông tin Intranet qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_service_hash_cracked	Thực nghiệm thám mã Kerberoasting bẻ khóa thành công mật khẩu dịch vụ yếu (TC2)	COMPLETED

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_complex_key_remediated	Thực nghiệm kiểm chứng nâng cấp mật khẩu phức tạp chặn đứng tấn công từ điển (TC3)	COMPLETED
goal_aes256_enforced	Kiểm chứng KDC và dịch vụ bắt buộc áp dụng chuẩn mã hóa cấp cao AES-256 (TC4)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 5/5 mục tiêu bài thực hành sso-kerberoasting



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (5/5 Goals Satisfied)

Kết luận: Bài thực hành 'sso-kerberoasting' làm rõ một trong những kỹ thuật tấn công leo thang đặc quyền phổ biến nhất nhắm vào tài khoản dịch vụ trong các hệ thống Single Sign-On Kerberos. Việc chuyển đổi từ mật khẩu do con người đặt sang Keytab ngẫu nhiên hóa (hoặc Group Managed Service Accounts - gMSA), kết hợp loại bỏ chuẩn mã hóa cũ RC4 để bắt buộc chuẩn mã hóa AES-256 là biện pháp then chốt để bảo vệ tuyệt đối hạ tầng danh tính doanh nghiệp.